

MODULE 9.4

Application Security

Endpoint Security | Cisco Networking Academy
Prepared by: Kudzaishe Majeza

Cybersecurity Essentials

Topics Covered:

9.4.1 Attack Surface • Vulnerability vs Attack Surface • SANS Three Components

9.4.1 An Expanding Attack Surface • IoT • BYOD • Cloud • Mobility

9.4.2 Application Block list and Allow list • Blocklisting vs Allow listing

9.4.2 Implementation Tools • Windows Local Group Policy Editor • Cisco Talos • Spamhaus

9.4.3 System-Based Sandboxing • Isolation Techniques • Analysis Environments

9.4.1 Attack Surface

The total sum of all vulnerabilities in a system that are accessible to an attacker

A vulnerability is a weakness in a system or its design that could be exploited by a threat. An attack surface is the total sum of the vulnerabilities in a given system that is accessible to an attacker. The attack surface can consist of open ports on servers or hosts, software that runs on internet-facing servers, wireless network protocols, and even users.

The SANS Institute describes three components of the attack surface:

Network Attack Surface

- All open ports, protocols, and services exposed on the network
- Includes internet-facing servers, routers, switches, and access points
- Wireless network protocols and connections
- Any network service that an attacker could interact with remotely

Software Attack Surface

- All code that can be executed on a host or server
- Includes web applications, APIs, and internet-facing services
- Unpatched software with known vulnerabilities
- Third-party libraries and dependencies that may contain flaws

Human Attack Surface

- Users who can be socially engineered or tricked
- Phishing, pretexting, and other social engineering techniques
- Privileged users whose credentials are high-value targets
- Any person with access to systems or sensitive information

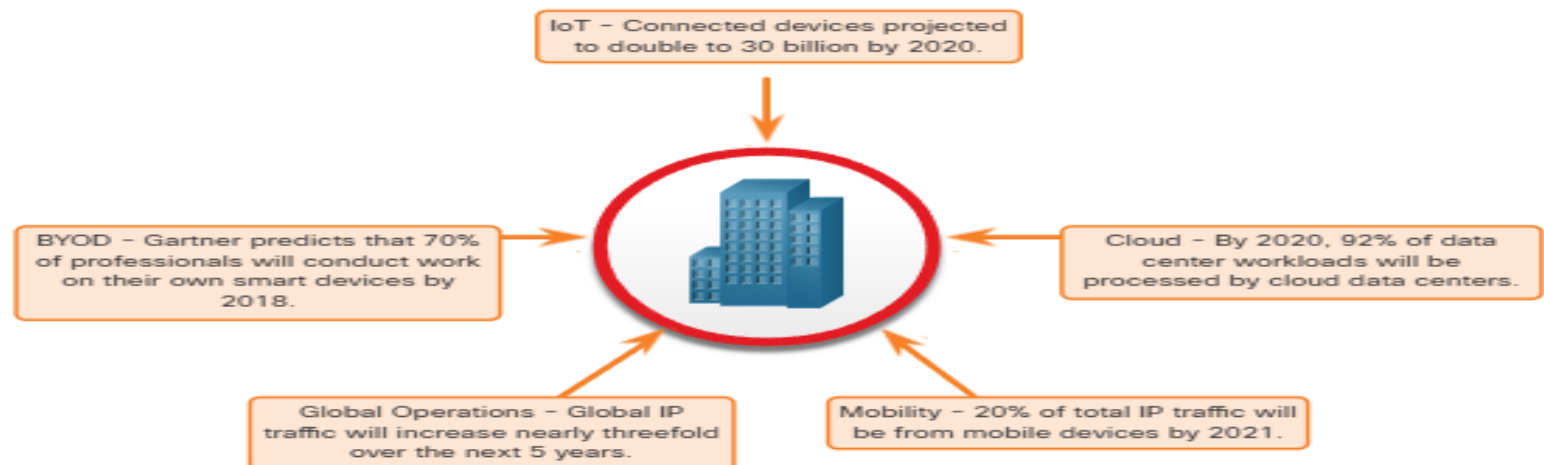
9.4.1 An Expanding Attack Surface

Why the attack surface keeps growing — five key trends driving the expansion

The attack surface is continuing to expand. More devices are connecting to networks through IoT and BYOD. Much of network traffic now flows between devices and cloud locations. Mobile device use continues to increase — all of these trends contribute to a prediction that global IP traffic will increase threefold in the next five years.

IoT	BYOD	Cloud	Mobility	Global IP Traffic
Connected devices projected to double to 30 billion	Gartner predicts 70% of professionals will use own smart devices for work	By 2020, 92% of data centre workloads processed by cloud data centres	20% of total IP traffic will be from mobile devices	Global IP traffic will increase nearly threefold over the next 5 years

Expanding Attack Surface Diagram:



9.4.2 Application Block list and Allow list

Reducing the attack surface by controlling which applications are permitted to run

One way of decreasing the attack surface is to limit access to potential threats by creating lists of prohibited applications — this is known as blocklisting. Similarly, allow lists specify which programs ARE allowed to run, preventing known vulnerable applications from creating vulnerabilities on network hosts.

Block Lists (Blocklisting)

Prevent Only

- A list of applications that are PROHIBITED from running
- Any software on the blocklist is automatically blocked
- Blocks known malicious or vulnerable applications
- Blacklists can be manually created by IT administrators
- Or obtained from security services and updated automatically
- Cisco Firepower accesses Cisco Talos for blocklist data
- The Spamhaus Project provides a free blocklist service

Allow Lists (Allow listing)

Allow Only

- A list of applications that ARE permitted to run
- Only software on the allow list can execute — everything else is blocked
- Allow lists are based on an organisation's security baseline
- The baseline defines an accepted level of risk and environment
- Non-allowlisted software can violate the security baseline
- More restrictive than blocklisting — higher security posture
- Reduces attack surface by limiting software to trusted applications

9.4.2 Block/Allow List Implementation

Tools and services used to enforce application control policies

Block and allow lists can be implemented through operating system tools, enterprise security platforms, and external threat intelligence services that automatically maintain and distribute up-to-date blacklists across an organisation.

Windows Local / Group Policy Editor

- Built-in Windows tool for enforcing application policies
- Software Restriction Policies control which programs can run
- Policies can be applied per-user or per-machine
- Supports path rules, hash rules, and certificate rules
- Centrally distributed to all domain machines via Active Directory

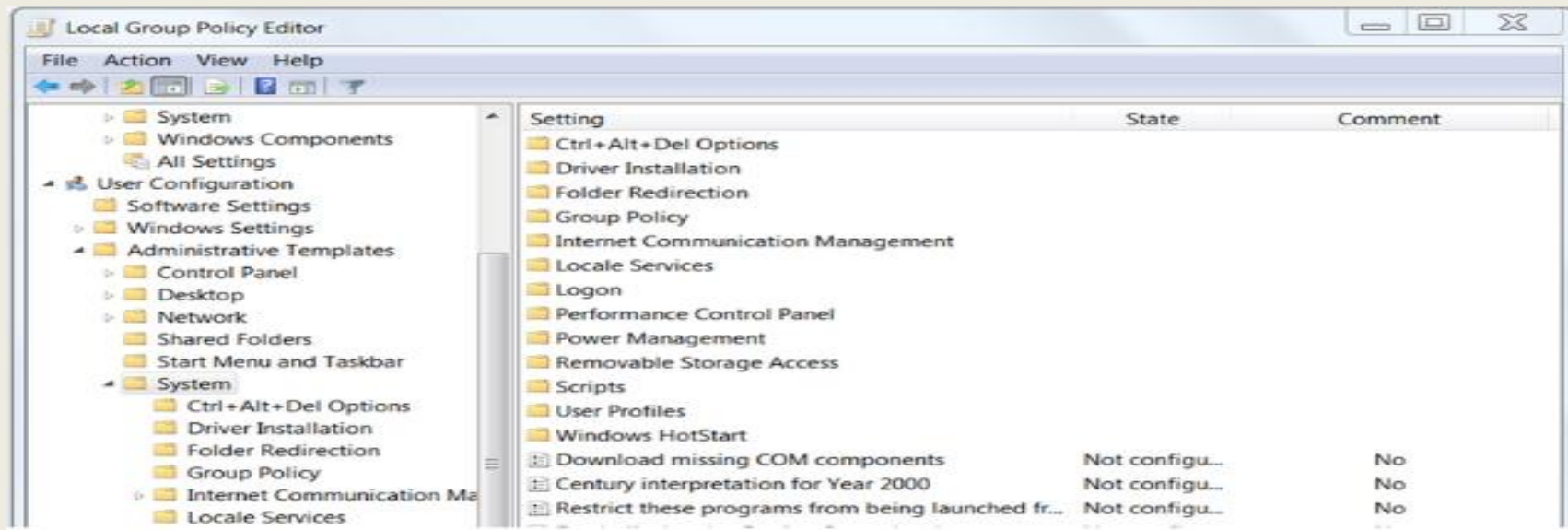
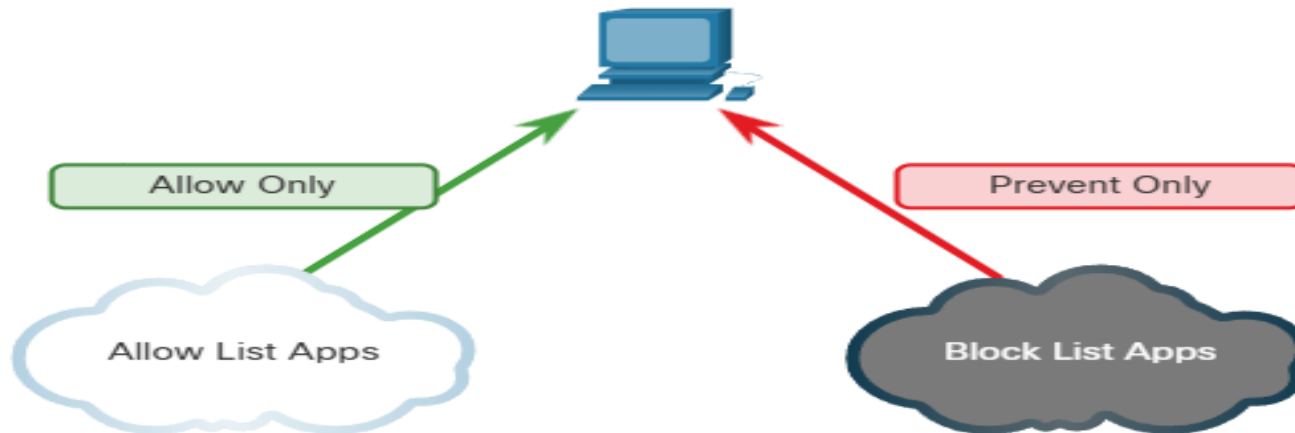
Cisco Firepower / & Cisco Talos

- Cisco Firepower is an enterprise security management system
- Accesses the Cisco Talos security intelligence service
- Talos maintains one of the world's largest threat intelligence databases
- Blacklists are automatically downloaded and distributed
- Applied to firewalls and security devices across the enterprise network

The Spamhaus Project

- A free and widely-used blacklist service
- Tracks known spam sources, malware hosts, and botnets
- Blacklists can be integrated into firewalls and security systems
- Free for personal and small-scale use
- Provides DNS-based blocklists (DNSBLs) for easy integration

Windows Local Group Policy Editor — Software Restriction Policies:



9.4.3 System-Based Sandboxing

A technique to safely execute and analyse suspicious software in an isolated environment

Sandboxing is a technique that allows suspicious files to be executed and analysed in a safe environment. Important methods include network-based sandboxing and Windows sandbox features. The sandbox runs programs in an isolated environment, allowing behaviour to be observed without allowing it to affect the rest of the system.

How Sandboxing Works — The Core Principle:

A sandbox is an isolated environment with controlled access to the host system. Suspicious files or programs are placed inside the sandbox and allowed to execute. The sandbox monitors all activity — file system access, network connections, registry changes, process creation — and reports on the behaviour without allowing the malware to escape the container.

Behavioural Analysis

- Observe what a suspicious file DOES, not just what it looks like
- Catches zero-day malware that bypasses signature detection
- Monitors file creation, deletion, and modification events
- Tracks registry changes made by the analysed program

Network Isolation

- Sandbox is isolated from the production network
- Network traffic from the sandboxed program is captured and analysed
- Prevents malware from communicating with C2 servers
- Identifies DNS lookups and attempted exfiltration

Windows Sandbox Features

- Windows Sandbox: a lightweight desktop environment for testing
- Disposable — all changes are discarded when the sandbox closes
- Built into Windows 10/11 Pro and Enterprise
- Each session starts fresh with a clean installation

Enterprise Sandboxing Solutions

- Cisco Threat Grid — cloud-based malware analysis platform
- Palo Alto WildFire — automated malware analysis service
- FireEye — advanced threat detection with sandboxing
- AMP sandbox — integrated with Cisco AMP for endpoints

The image displays a Windows Sandbox environment running on ANY.RUN. The desktop features a blue background with the Windows logo and various icons including Recycle Bin, Acrobat Reader DC, Firefox, Google Chrome, Opera, Skype, and VLC media player. A taskbar at the bottom shows the Start button and several open applications. On the right side, a malware analysis interface is visible, titled "Malicious activity". It shows details for "HJdyTsp.exe", including its MD5 hash, start time, and total time. Below this, there are buttons for "Get sample", "IOC", "Restart", and "Export". A "Text report" button is also present. The interface includes a "PROCESS" list with columns for "Filter by name or PID" and "Show only imports". The list shows several processes, including "HJdyTsp.exe" and "RegAsm.exe". The "PROCESS DETAILS" section for "RegAsm.exe" shows its version, build, and assembly information. A "DANGER" section indicates that "NANOCORE was detected". A "WARNING" section states "Creates files in the user directory". A "100 out of 100" status indicator is visible in the bottom right corner of the interface.

Windows Sandbox / Network-based sandbox environment

Module 9.4 — Summary

Attack Surface	Total sum of all vulnerabilities in a system accessible to an attacker — ports, software, users.	SANS Components	Three components: Network Attack Surface, Software Attack Surface, and Human Attack Surface.
Expanding Surface	IoT (30B devices), BYOD (70% of pros), Cloud (92% workloads), Mobility, and rising global IP traffic.	Block Lists	Lists of PROHIBITED applications — automatically blocked from executing on hosts.
Allow Lists	Lists of PERMITTED applications — only these can run. More restrictive and higher security posture.	Implementation	Windows Local Group Policy Editor, Cisco Firepower + Talos, and Spamhaus Project (free service).
Sandboxing	Isolated environment to safely execute and analyse suspicious files — observes behaviour without risk.	Sandbox Tools	Windows Sandbox (built-in), Cisco Threat Grid, Palo Alto WildFire, FireEye, and Cisco AMP sandbox.